

Risk Vs Compliance in IT Policy

Rosenel Roy

Department of Information Technology, University of the Cumberland

Info Tech in a Global Economy (ITS-832-A03)

Professor John Bosire

September 9, 2026

When companies follow risk-based and compliance-driven approaches, they usually implement comparable IT controls. However, their decision criteria may vary. A compliance-driven policy focuses on demonstrating that the organization has satisfied its legal, regulatory, and audit requirements. It prioritizes documented approvals, repeatable procedures, controlled evidence, and defined review schedules. A risk-based policy evaluates the likelihood and possible effects of unauthorized access, control failure, or operational disruption. Compliance highlights what an organization needs to demonstrate, while risk management determines which exposures require timely attention and the strongest risk-eradication treatment.

This distinction is particularly visible in identity and access management. During my IAM experience, I supported the transition of 84 SOX-relevant applications, classified among different risk levels, into BeyondTrust privileged access management. The change in access generally creates administrative overhead and requires compliance controls such as documented access approvals, role-specific access control, least-privilege enforcement, separation of duties, and evidence of access reviews. However, applying the same administrative process to every application would not reduce risk at the same rate. Software applications containing privileged functions or access to financially significant information required greater examination and presented a higher risk than applications with limited business impact.

Sandhu et al. (1996) provides an insight into this difference. According to their role-centric access control model, permission assignment is based on company roles rather than directly on the end user. The model includes hierarchies and constraints among roles, including restrictions on the separation of duty. The concepts apply directly to enterprise IAM, since a technically completed role assignment is not automatically appropriate. The role must be

appropriate to the subject's job function, have appropriate entitlements, and avoid conflicting access. This is why IAM works with SailPoint, BeyondTrust, and application owners, and why manual provisioning can't be reduced to access requests. It is necessary to continuously reevaluate accessibility.

For this example, the IAM team may need to perform scheduled access certifications for audit, as well as investigate an active privileged account with excessive entitlements. The certification date is fixed, while the privileged account may pose a greater risk of exposure. A response prioritizing compliance may complete the review of records. A response focusing on risk may divert staff to search and fix. On the contrary, risk perception could lead to partial approvals, inconsistent exceptions, or a lack of evidence. Tension arises between security teams, application owners, auditors, and business managers over priorities, resources, and acceptable residual risk.

The NIST Risk Management Framework provides a systematic approach for managing risk through the steps: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor. The categorization phase enables assessment of systems based on their possible impact. Control selection and tailoring align safeguards with corporate risk, mission objectives, and operational circumstances. Assessment and authorization require documented evidence that controls have been implemented and that any residual risk has been explicitly accepted by an accountable official. Continuous monitoring is significant for identity and access management (IAM), as identities, employment status, roles, entitlements, and application risks may evolve after initial approval. While the RMF does not ensure (SOX) compliance, its processes for documentation, assessment, accountability, and monitoring can facilitate compliance when appropriately mapped to relevant requirements (Joint Task Force, 2018).

In conclusion, compliance demonstrates that the required process occurred; risk management tests whether that process is protecting the organization.

REFERENCES

Joint Task Force. (2018). *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy* (NIST Special Publication 800-37, Revision 2). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-37r2>

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer*, 29(2), 38–47. <https://doi.org/10.1109/2.485845>

